Cronicle Docker-image Hard-coded Key to RCE

Researcher	Kashish Topiwala
Product	Cronicle (third-party Docker images)
Affected	soulteary/cronicle, intelliops/cronicle, cronicle/cronicle, nicholasamorim/cronicle
CWE	CWE-798 Use of Hard-coded Credentials
CVSS 3.1	9.8 Critical (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

Summary

Cronicle is a self-hosted job scheduler. Its worker servers accept a server-to-server authentication whose token is derived from a shared secret key, and then run any command a request asks for. Several Cronicle Docker images bake a fixed secret key into the image, so the key is the same for everyone who pulls the image. Any remote attacker can therefore forge the authentication and run commands. The tested image runs as root, so the attacker gets code execution as root.

Steps to reproduce

1. Pull one of the affected Cronicle Docker images and read its baked secret key. The key is stored inside the published image, so it is the same for every pull.
2. Connect to the worker port and send a forged master authentication. The token is the sha256 of the master host name, the current time, and the baked secret key.
3. Send a launch_job message with a command. The worker runs the command with no login.
4. Confirm the command ran as root on the worker.



Impact

- Any remote attacker who pulls the same public image learns the secret key.
- The attacker runs arbitrary commands on the worker with no login.
- The tested image runs as root, so the attacker gets root code execution.
- The key is static in the image, so every deployment of that image shares it.

Remediation

- Do not bake a secret key into the image. Generate it at first run, or require the operator to supply it.
- Rotate the secret key on existing deployments.
- Restrict the worker port to the internal network.

References

- https://github.com/jhuckaby/Cronicle
- https://cwe.mitre.org/data/definitions/798.html